

PIÈCE JOINTE 01

CyberMind — plateforme SBXOS · version 1.0

Présentation du projet SecuBox

1. Résumé exécutif

SecuBox est une appliance de sécurité souveraine développée et éditée par CyberMind, entreprise indépendante de cybersécurité établie à Notre-Dame-du-Cruet (Savoie). Elle repose sur **SBXOS**, un système d'exploitation durci construit sur une base Debian stable pour architecture ARM64, dont l'intégralité de la chaîne de compilation, de configuration et de durcissement est maîtrisée par l'éditeur. L'appliance regroupe en un point unique les fonctions de filtrage applicatif (WAF), de segmentation réseau, de protection DNS, de terminaison VPN et de journalisation horodatée.

Le projet vise une **protection par conception** : les mesures de sécurité et de protection des données à caractère personnel sont intégrées au socle logiciel et actives par défaut, sans action de configuration de la part de l'utilisateur final. La démarche s'inscrit dans une perspective de qualification **CSPN (ANSSI)** et dans le respect des articles 5, 25 et 32 du Règlement (UE) 2016/679. Le présent dossier est adressé à la Commission nationale de l'informatique et des libertés dans un but de transparence documentaire et de conformité démontrable, préalablement à tout déploiement à destination du public.

2. Les quatre objectifs du projet

**01 · Protéger**

Interposer une barrière applicative et réseau entre l'utilisateur et les menaces d'Internet, sans exposer ses données à un tiers.

**02 · Minimiser**

Ne collecter que les données strictement nécessaires au fonctionnement et à la sécurité, pour une durée strictement bornée.

**03 · Rendre lisible**

Donner à l'utilisateur une vision claire et compréhensible de ce qui est journalisé, pourquoi, et pendant combien de temps.

**04 · Rendre souverain**

Héberger et maîtriser localement le traitement : aucun transfert hors Union européenne, aucune dépendance à un service tiers.

3. Publics concernés

Public	Contexte d'usage	Nature de la relation	Volumétrie estimée
Particuliers et foyers	Protection du réseau domestique, filtrage DNS, chiffrement des accès distants	Utilisateur final, responsable de traitement pour son usage privé	1 à 10 postes
Très petites entreprises, artisans, professions libérales	Sécurisation du poste de travail et des services métiers hébergés	Client, responsable de traitement assisté par CyberMind (sous-traitant technique)	5 à 50 postes
Collectivités et petites communes	Accès Internet public maîtrisé, réseau interne segmenté (programme VILLAGE3B, PJ 06)	Client public, responsable de traitement	50 à 500 utilisateurs
Associations et tiers-lieux	Point d'accès partagé, atelier numérique, médiation	Client, responsable de traitement	20 à 200 utilisateurs
Intégrateurs et revendeurs	Déploiement et exploitation de parcs d'appliances pour compte de tiers	Partenaire, sous-traitant au sens de l'article 28 du RGPD	Variable

**« Prévenir plutôt que réparer »**

La doctrine du projet SecuBox tient en une phrase : **il coûte toujours moins cher, techniquement comme humainement, d'empêcher une donnée d'être exposée que de gérer sa fuite**. Cette position se traduit par trois règles non négociables inscrites dans le socle SBXOS : (1) toute donnée non nécessaire n'est pas collectée ; (2) toute donnée collectée est cloisonnée, chiffrée au repos et purgée automatiquement à l'échéance ; (3) toute fonction nouvelle fait l'objet d'une analyse de nécessité et de proportionnalité avant intégration. La protection des données n'est donc pas une couche ajoutée en fin de cycle, mais un critère de conception au même titre que la performance ou la disponibilité.



Références du dossier. Socle logiciel : **secubox-deb** (SBXOS) — dépôt de référence github.com/CyberMind-FR/secubox-deb. Licence **CMSD-1.0** (LicenseRef-CMSD-1.0), source-available. Éditeur : CyberMind, SIREN 409 743 275. Contact : contact@cybermind.fr.

Architecture technique SBXOS / SecuBox

1. Objet du document

La présente pièce décrit l'architecture technique de l'appliance SecuBox et du système SBXOS qui la porte, dans la mesure nécessaire à l'appréciation des garanties offertes aux personnes concernées. Elle expose la chaîne de traitement du flux réseau depuis son entrée en provenance d'Internet jusqu'aux services internes, identifie les composants qui traitent ou journalisent des données à caractère personnel, décrit les flux de données associés et récapitule les mesures de protection mises en œuvre. Elle constitue le support technique des pièces jointes 03 (registre), 04 (mesures) et 05 (analyse d'impact).

2. Chaîne de traitement

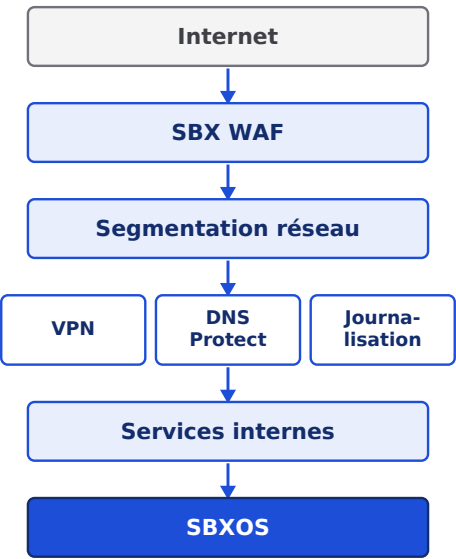


Figure 1 — Chaîne de traitement du flux réseau

3. Tableau des composants

Composant	Fonction	Données traitées
SBX WAF	Filtrage applicatif HTTP/HTTPS, blocage des attaques injectives, limitation de débit	Adresse IP source, URL demandée, en-tête User-Agent
Segmentation réseau	Cloisonnement VLAN et règles nftables entre zones (public, interne, administration)	Adresses IP, ports, métadonnées de flux
VPN (WireGuard)	Terminaison des accès distants chiffrés	Clé publique, adresse IP d'origine, horodatage de session
DNS Protect	Résolution filtrée locale, blocage des domaines malveillants, DoT/DoH sortant	Requête DNS, adresse IP interne, horodatage
Journalisation	Collecte locale horodatée et signée des événements de sécurité	Événements techniques, IP, identifiants d'administration
Services internes	Services métiers hébergés sur l'appliance (portail, partage, supervision)	Selon service, cf. registre PJ 03
SBXOS	Socle durci : noyau restreint, démarrage vérifié, chiffrement du stockage, mises à jour signées	Aucune donnée personnelle propre au socle

4. Flux des données

- **Entrée.** Le flux entrant est terminé par le WAF, qui inspecte la requête applicative et rejette les tentatives d'exploitation avant tout accès aux services.
- **Cloisonnement.** Le flux accepté est routé vers la zone réseau strictement correspondant au service visé ; aucune communication latérale entre zones n'est autorisée par défaut.
- **Résolution et chiffrement.** Les résolutions DNS sont traitées localement et les accès distants encapsulés dans un tunnel chiffré ; aucune donnée de navigation ne transite en clair.
- **Journalisation.** Seuls les événements de sécurité sont journalisés, localement, en écriture seule, avec horodatage et purge automatique à l'échéance de conservation.
- **Restitution.** La réponse est renvoyée à l'utilisateur ; aucune copie du contenu applicatif n'est conservée.

5. Mesures de protection

- Chiffrement intégral du stockage (LUKS2) et des sauvegardes.
- TLS 1.3 imposé, suites obsolètes désactivées, HSTS actif.
- Démarrage vérifié et paquets signés (chaîne de confiance CyberMind).
- Comptes d'administration nominatifs, second facteur obligatoire.
- Journaux en écriture seule, horodatés, à rotation et purge automatiques.
- Aucun transfert hors Union européenne ; traitement local par conception.
- Séparation stricte des plans d'administration et de production.

🔒 Conclusion au regard du RGPD

L'architecture décrite met en œuvre la protection des données dès la conception et par défaut au sens de l'article 25 : la minimisation est structurelle (aucun composant ne collecte de contenu applicatif), la sécurité du traitement répond aux exigences de l'article 32 (chiffrement, cloisonnement, intégrité, disponibilité, traçabilité), et la localisation exclusivement locale du traitement écarte la question des transferts au sens du chapitre V. Les données à caractère personnel effectivement traitées se limitent aux métadonnées techniques indispensables à la sécurité du réseau, recensées au registre figurant en pièce jointe 03.

PIÈCE JOINTE 03

Article 30 du Règlement (UE) 2016/679

Registre des traitements RGPD

Le registre ci-après recense les traitements mis en œuvre par l'apppliance SecuBox dans sa configuration par défaut. Responsable de traitement : **CyberMind, SIREN 409 743 275**, pour les traitements liés à l'édition et au support ; l'exploitant de l'apppliance est responsable de traitement pour les traitements opérés sur son propre réseau, CyberMind intervenant alors comme sous-traitant au sens de l'article 28.

1. Registre des traitements

Traitement	Finalité	Base légale	Durée de conservation
Journalisation des événements de sécurité	Détection, investigation et preuve des incidents de sécurité affectant le réseau protégé	Intérêt légitime (art. 6.1.f) — sécurité du système d'information	12 mois glissants, purge automatique
Filtrage applicatif (WAF)	Blocage des requêtes malveillantes visant les services exposés	Intérêt légitime (art. 6.1.f)	Journal d'alerte : 12 mois ; requête bloquée : 30 jours
Résolution DNS filtrée	Blocage des domaines malveillants, protection contre l'hameçonnage	Intérêt légitime (art. 6.1.f)	Cache : 24 heures ; journal d'incident : 6 mois
Gestion des accès VPN	Authentification et traçabilité des accès distants au réseau interne	Exécution du contrat (art. 6.1.b) — relation employeur/prestataire	Compte : durée de la relation ; journal de connexion : 12 mois
Administration de l'apppliance	Gestion des comptes administrateurs, configuration, mises à jour	Exécution du contrat (art. 6.1.b) et obligation légale (art. 6.1.c)	Compte : durée du contrat + 1 an ; journal d'action : 3 ans
Portail d'accès public (VILLAGE3B)	Ouverture d'un accès Internet public maîtrisé et conforme (cf. PJ 06)	Consentement (art. 6.1.a) et obligation légale de conservation	Consentement : 13 mois ; données de connexion : 12 mois
Support et maintenance	Traitement des demandes d'assistance et diagnostic des anomalies	Exécution du contrat (art. 6.1.b)	3 ans à compter du dernier contact

2. Catégories de données traitées

Catégorie	Données concernées	Origine	Sensibilité
Données d'identification technique	Adresse IP source et interne, adresse MAC, identifiant de session, clé publique VPN	Collecte automatique (flux réseau)	Ordinaire
Données de connexion	Horodatage de connexion et de déconnexion, volumétrie, port et protocole	Collecte automatique	Ordinaire
Données d'usage technique	Domaine résolu, URL demandée en cas de blocage, en-tête User-Agent, code de réponse	Collecte automatique	Ordinaire
Données de compte	Identifiant, nom, adresse électronique professionnelle, rôle, empreinte du second facteur	Saisie par l'exploitant	Ordinaire
Données de support	Contenu des demandes d'assistance, éléments de diagnostic transmis volontairement	Fournies par la personne	Ordinaire
Catégories particulières (art. 9)	Aucune. Le contenu applicatif n'est ni inspecté en clair ni conservé ; aucun profilage n'est réalisé	—	Sans objet

3. Destinataires des données

Destinataire	Qualité	Données transmises	Localisation
Exploitant de l'apppliance	Responsable de traitement	Ensemble des données traitées localement	France
CyberMind — équipe support	Sous-traitant (art. 28)	Éléments de diagnostic transmis explicitement lors d'une demande d'assistance	France
Autorité judiciaire ou administrative habilitée	Tiers autorisé	Données de connexion, sur réquisition régulière uniquement	France
Tiers commerciaux, régies, analytique	—	Aucune donnée transmise. Aucun traceur tiers, aucune monétisation, aucun transfert hors Union européenne	Sans objet



Droits des personnes. Toute demande d'accès, de rectification, d'effacement, de limitation ou d'opposition peut être adressée au délégué à la protection des données de l'exploitant ou, pour les traitements relevant de l'éditeur, à contact@cybermind.fr. Une réponse est apportée dans le délai d'un mois prévu à l'article 12.3, avec possibilité de réclamation auprès de la CNIL.

PIÈCE JOINTE 04

Article 32 du Règlement (UE) 2016/679

Mesures techniques et organisationnelles

Les mesures décrites ci-après sont actives par défaut dans la configuration d'usine de l'appliance SecuBox. Elles sont organisées en couches successives : chaque couche suppose la précédente compromise et limite la portée d'une éventuelle défaillance. Ce principe de défense en profondeur garantit qu'aucune mesure unique ne constitue un point de rupture pour la confidentialité des données à caractère personnel.

1. Architecture de défense en couches

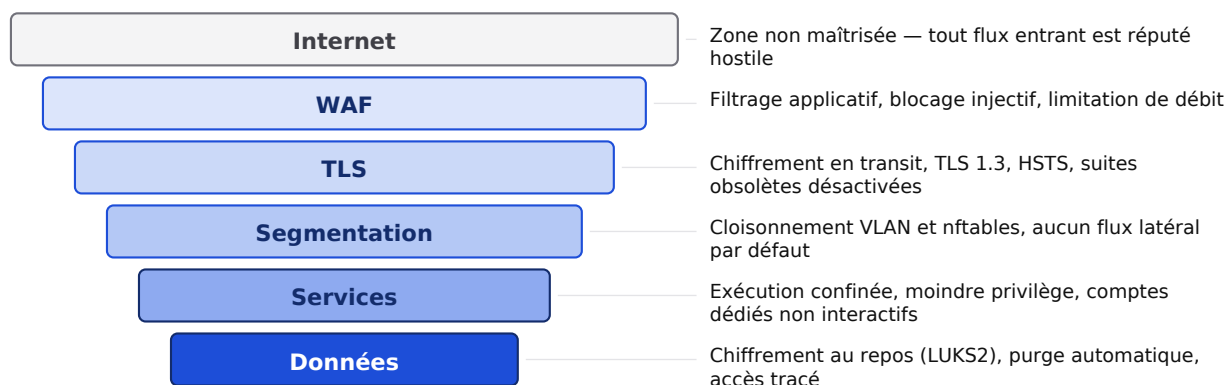


Figure 2 — Défense en profondeur : de la zone hostile à la donnée

2. Mesures techniques détaillées

Domaine	Mesure mise en œuvre	Portée
Chiffrement	Chiffrement intégral du stockage par LUKS2 (AES-XTS 256) ; TLS 1.3 imposé pour tout flux exposé ; tunnels VPN WireGuard (ChaCha20-Poly1305) ; sauvegardes chiffrées avant export	Confidentialité au repos et en transit
Contrôle d'accès	Comptes administrateurs nominatifs, second facteur obligatoire, absence totale de compte ou de mot de passe par défaut, séparation des rôles, expiration automatique des sessions	Confidentialité, imputabilité
Durcissement du socle	Noyau Linux restreint (modules signés, chargement verrouillé après amorçage), démarrage vérifié, dépôts et paquets signés par CyberMind, surface applicative réduite au strict nécessaire, confinement systemd et cgroups des services	Intégrité, résistance à l'escalade
Cloisonnement	Segmentation VLAN et filtrage nftables par zone ; plan d'administration physiquement ou logiquement séparé du plan de production ; aucun flux latéral autorisé par défaut	Limitation de la propagation
Détection et intégrité	Surveillance d'intégrité du système de fichiers et détection anti-rootkit, alerte sur exécution de binaire non issu du gestionnaire de paquets, journaux horodatés et signés	Détection, preuve
Cycle de vie de la donnée	Purge automatique à l'échéance de conservation, rotation des journaux, effacement sécurisé lors de la réinitialisation ou du retrait de l'appliance	Minimisation, limitation de conservation
Disponibilité	Sauvegarde chiffrée planifiée, mises à jour de sécurité signées, restauration testée, procédure de retour à un état sain documentée	Disponibilité, résilience

3. Mesures organisationnelles

- Documentation de conception et de durcissement maintenue à jour, revue à chaque version.
- Procédure de gestion des vulnérabilités et de publication de correctifs signés.
- Procédure de notification de violation de données conforme aux articles 33 et 34, avec délai cible interne de 24 heures avant notification.
- Journal des actions d'administration conservé trois ans et non modifiable par l'exploitant.
- Contrats de sous-traitance conformes à l'article 28 pour toute intervention de CyberMind.
- Accès aux données de support limité aux personnes désignées, sur demande explicite de l'exploitant et pour la durée de l'intervention.
- Démarche de qualification CSPN (ANSSI) : cible de sécurité, analyse de conformité et évaluation par un centre agréé.
- Sensibilisation et documentation d'exploitation fournies à chaque déploiement.

🔧 Appréciation au regard de l'article 32

L'ensemble des mesures ci-dessus est appliqué **par défaut**, sans action de configuration de l'exploitant, et vérifié à chaque publication d'une version de SBXOS. Il couvre les quatre exigences de l'article 32.1 — chiffrement, garantie de confidentialité, d'intégrité, de disponibilité et de résilience, rétablissement de l'accès après incident, évaluation régulière de l'efficacité — à un niveau proportionné aux risques analysés en pièce jointe 05.

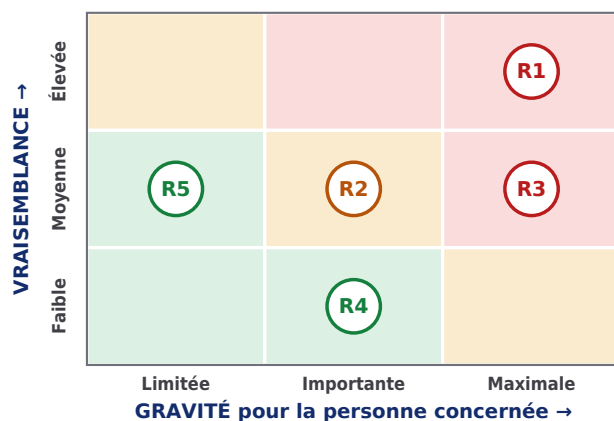
PIÈCE JOINTE 05

Article 35 du Règlement (UE) 2016/679

Analyse d'impact (AIPD)

L'analyse ci-après porte sur les risques que le traitement fait peser sur les droits et libertés des personnes concernées. Elle est conduite selon la méthode publiée par la CNIL (PIA), en croisant la **gravité** des conséquences pour la personne et la **vraisemblance** de survenance du scénario, avant puis après application des mesures décrites en pièce jointe 04.

1. Matrice des risques (avant mesures)



Scénarios de risque étudiés

- R1 Usurpation d'identité** Élevé
Détournement d'un compte d'administration ou d'un accès VPN permettant d'agir au nom d'une personne légitime.
- R2 Fuite de journaux** Moyen
Exfiltration de journaux techniques révélant des habitudes de connexion et des adresses IP rattachables à une personne.
- R3 Compromission Web** Élevé
Exploitation d'une vulnérabilité d'un service exposé conduisant à l'exécution de code et à l'accès aux données hébergées.
- R4 Perte de disponibilité** Faible
Indisponibilité de l'appliante privant l'exploitant de son accès réseau et de ses journaux de preuve.
- R5 Conservation excessive** Faible
Maintien de données au-delà de la durée nécessaire par défaut de purge.

2. Mesures de réduction

Risque	Mesures de réduction appliquées	Effet attendu
R1 — Usurpation d'identité	Second facteur obligatoire pour toute administration ; absence de compte par défaut ; clés VPN nominatives et révocables ; expiration automatique des sessions ; alerte sur connexion administrative inhabituelle ; journal d'action non modifiable	Vraisemblance ramenée de élevée à faible
R2 — Fuite de journaux	Journaux conservés localement, chiffrés au repos, en écriture seule ; minimisation des champs enregistrés ; purge automatique à 12 mois ; accès restreint aux comptes d'administration tracés ; aucun export automatique vers un tiers	Gravité ramenée de importante à limitée
R3 — Compromission Web	WAF en coupure, services confinés et exécutés en moindre privilège, segmentation interdisant tout rebond, surveillance d'intégrité et anti-rootkit, mises à jour signées, démarrage vérifié	Vraisemblance ramenée de élevée à moyenne , portée fortement réduite
R4 — Perte de disponibilité	Sauvegarde chiffrée planifiée, restauration testée, procédure de retour à un état sain, supervision de l'état du matériel	Risque maintenu au niveau faible
R5 — Conservation excessive	Durées de conservation codées dans le socle, purge automatique vérifiée, contrôle périodique documenté	Risque maintenu au niveau faible



Risque résiduel

Après application des mesures techniques et organisationnelles décrites en pièce jointe 04, le risque résiduel est évalué comme **faible à modéré**. Aucun scénario ne demeure en zone critique de la matrice. Le risque résiduel le plus élevé reste la compromission d'un service Web exposé (**R3**), dont la vraisemblance ne peut être ramenée à zéro mais dont la portée est confinée par la segmentation et le moindre privilège : une compromission ne donne accès ni aux journaux, ni au plan d'administration, ni aux données des autres zones. Ce niveau est jugé **acceptable** au regard des finalités poursuivies. L'analyse est révisée à chaque version majeure de SBXOS, ainsi qu'à l'occasion de tout incident de sécurité significatif ou de toute évolution fonctionnelle touchant aux données.

PIÈCE JOINTE 06

VILLAGE3B

Déploiement en accès public — parcours utilisateur

VILLAGE3B désigne le déploiement de SecuBox en contexte d'accès Internet public : mairie, bibliothèque, tiers-lieu, place de village ou hébergement collectif. Le dispositif offre un accès Wi-Fi ouvert au public tout en garantissant la conformité de l'exploitant à ses obligations de conservation des données de connexion, sans recourir à un prestataire tiers ni à une plateforme extérieure. L'ensemble du traitement s'effectue localement, sur l'appliance installée dans la commune.

1. Parcours utilisateur

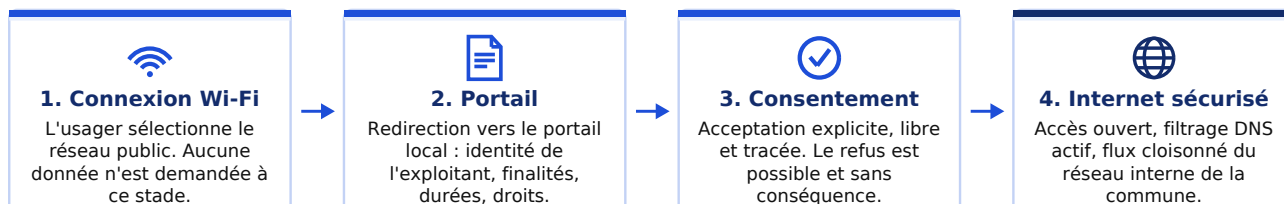


Figure 3 — Parcours de l'utilisateur du point d'accès public VILLAGE3B

2. Données collectées lors du parcours

Étape	Donnée collectée	Finalité	Conservation
1. Connexion Wi-Fi	Adresse MAC du terminal, horodatage d'association	Établissement technique de la liaison radio	Session en cours, puis 12 mois en journal
2. Portail	Adresse IP attribuée, type de navigateur (en-tête User-Agent)	Affichage du portail et sécurité du point d'accès	12 mois
3. Consentement	Horodatage, version du texte accepté, identifiant technique de session	Preuve du consentement (art. 7.1)	13 mois
4. Internet sécurisé	Horodatage de début et de fin, volumétrie, domaines bloqués par le filtrage	Obligation de conservation des données de connexion et sécurité du réseau	12 mois
Aucune étape	Nom, adresse électronique, numéro de téléphone, pièce d'identité, contenu consulté, historique de navigation	Non collectés. Aucune inscription, aucun compte, aucun traceur publicitaire	Sans objet

3. Droits des personnes concernées

- **Information (art. 12-13).** Le portail présente, avant toute acceptation, l'identité de l'exploitant, les finalités, la base légale, les durées de conservation et les voies de recours.
- **Consentement et retrait (art. 7).** Le consentement est recueilli par une action positive explicite ; il peut être retiré à tout moment en se déconnectant du réseau, aussi simplement qu'il a été donné.
- **Accès (art. 15).** L'utilisateur peut demander à l'exploitant la copie des données de connexion le concernant, sur justification de l'identifiant technique de sa session.
- **Effacement (art. 17).** Effacement de droit hors données de connexion soumises à obligation légale de conservation, lesquelles sont purgées automatiquement à l'échéance.
- **Opposition (art. 21).** L'utilisateur peut refuser le traitement en n'utilisant pas le point d'accès ; aucun autre service de la collectivité n'en est conditionné.
- **Réclamation (art. 77).** Toute personne peut introduire une réclamation auprès de la CNIL, dont les coordonnées figurent sur le portail.

✓ Conclusion

Le dispositif VILLAGE3B permet à une collectivité d'offrir un accès Internet public tout en satisfaisant ses obligations légales, sans externaliser aucune donnée : le traitement, la conservation et la purge s'effectuent sur l'appliance installée localement, sous la seule maîtrise de l'exploitant. La collecte est limitée aux métadonnées techniques strictement nécessaires, le consentement est recueilli de manière explicite et traçable, et aucune donnée n'est transmise à un tiers commercial ni transférée hors de l'Union européenne. CyberMind se tient à la disposition de la Commission pour tout complément, toute démonstration technique du dispositif ou toute vérification sur pièces et sur place.